

Hack The Box Write-Up: **Two Million**

Tim Ragg

20.02.2025

1 Description

As part of my hands-on learning in cybersecurity, I worked through the **TwoMillion** challenge from HackTheBox - a realistic CTF-style Linux machine that simulates a full attack chain. The box includes multiple vulnerabilities, such as invite code exploitation, API endpoint abuse, command injection, credential reuse, and a real-world kernel escalation via CVE-2023-0386.

2 Approach

I followed the official walkthrough to understand and reproduce each step independently, with a strong focus on internalizing the mechanics behind the exploits rather than just executing commands.

3 Key Learnings

At first, I found it challenging to know where to even start. There are so many possible paths in a penetration test, and I had to learn to look closer at smaller details.

For example, I paid special attention to how the login system responded to incorrect credentials. Was the error message different when entering a wrong username vs a wrong password? That's a potential information leak that can be used to enumerate valid users.

Tools like **sqlmap**, **gobuster**, and **XSSStrike** further help to automatically scan a website for known vulnerabilities. But also network behavior is extremely important. Are scripts loaded in the background? Can I look at them in plain text? Is it obfuscated?

In general, the whole process taught me how much valuable information can be hidden in the background.

4 Reflection

Before looking at the walkthrough, I always tried to solve each step on my own first. Only when I was stuck at something, I looked at the guide. This challenge showed me to slow down and ask questions like: "Why does this work?" or "What could happen in the background?". It also made me aware of how easy it is to overlook simple but dangerous and common things like password reuse, which I didn't think much about before. Working through TwoMillion made me more curious and careful and definitely more motivated to keep learning.